

Defense Mechanisms: Architectural, Runtime, and Coordination Layers

Defense Mechanisms: Architectural, Runtime, and Coordination Layers I

This section presents the defense mechanisms comprising CIF. We begin with the cognitive security operator posture (`sec:operator-posture`), then organize specific defenses into three categories: architectural (`sec:arch-defenses`), runtime (`sec:runtime-defenses`), and coordination (`sec:coord-defenses`). We analyze defense composition (`sec:defense-composition`) and cost-benefit tradeoffs (`sec:cost-benefit`).

Cognitive Security Operator Posture I

Before examining specific defense mechanisms, we introduce the conceptual framework that guides their deployment: the **cognitive security operator posture**. This is the proactive defensive stance required when securing systems whose attack surface spans beliefs, goals, and inter-agent coordination.

Cognitive Security Operator Posture II

Definition and Principles

Definition (Cognitive Security Operator Posture)

The cognitive security operator posture is a defensive configuration characterized by:

1. **Assume Breach:** Operate under the assumption that some cognitive states may already be compromised
2. **Defense in Depth:** Layer multiple independent defense mechanisms
3. **Continuous Verification:** Continuously verify beliefs, goals, and trust relationships rather than trusting initial state
4. **Graceful Degradation:** Maintain functionality under attack by isolating compromised components
5. **Observable Internals:** Make cognitive state inspectable for monitoring and forensics

This posture differs fundamentally from traditional perimeter security, which assumes trusted internals protected by boundary defenses. In cognitive systems, the “perimeter” is the agent’s reasoning process itself. attacks can originate from legitimate

Architectural Defenses I

Architectural Defenses II

Cognitive Firewall

Definition (Cognitive Firewall)

A classification function on incoming messages:

$$\mathcal{F} : \mathcal{M} \rightarrow \{\text{ACCEPT}, \text{QUARANTINE}, \text{REJECT}\} \quad (2)$$

Definition (Firewall Decision Rules)

$$\mathcal{F}(m) = \begin{cases} \text{REJECT} & \text{if } D_{\text{inj}}(m) > \tau_1 \\ \text{QUARANTINE} & \text{if } D_{\text{sus}}(m) > \tau_2 \\ \text{ACCEPT} & \text{otherwise} \end{cases} \quad (3)$$

where D_{inj} detects injection attempts and D_{sus} scores suspicious content.

Table 4: Firewall detector components.

Detector	Target	Method
D_{inj}	Injection attempts	Pattern matching + semantic analysis
D_{sus}	Suspicious content	Pattern matching + semantic analysis

Runtime Defenses I

Cognitive Tripwires

Definition (Canary Belief)

Known-state beliefs that trigger alerts if modified:

$$\mathcal{W} = \{(\omega_1, p_1^{\text{exp}}), \dots, (\omega_k, p_k^{\text{exp}})\} \quad (7)$$

Definition (Tripwire Alert Condition)

$$\exists j : |\mathcal{B}_i(\omega_j) - p_j^{\text{exp}}| > \epsilon_{\text{drift}} \Rightarrow \text{ALERT} \quad (8)$$

Table 5: Tripwire categories and detection targets.

Type	Example	Detection Target
Identity	"I am Agent-7"	Identity confusion attacks
Boundary	"Cannot access /etc/passwd"	Capability elicitation
Principal	"My principal is Alice"	Authority hijacking
Temporal	"Session started at T "	Context manipulation

Runtime Defenses II

Behavioral Invariants

Definition (Invariant Set)

Pre-defined predicates that must hold:

$$\mathcal{J}_{\text{inv}} = \{I_1, \dots, I_m\} \quad (9)$$

Definition (Runtime Invariant Check)

$$\forall t, \forall I_k \in \mathcal{J}_{\text{inv}} : \sigma_i^t \models I_k \quad (10)$$

Core Invariants:

INV-1: Never execute code from untrusted sources

INV-2: Never leak principal credentials

INV-3: Never modify system files without explicit permission

INV-4: Always verify tool outputs before downstream use

INV-5: Never trust delegated trust $>$ direct trust

Runtime Defenses III

Drift Detection

Definition (Drift Detection)

Monitor belief distribution for anomalous changes:

$$D_{\text{KL}}(\mathcal{B}_i^t \| \mathcal{B}_i^{t-w}) > \theta_{\text{drift}} \Rightarrow \text{ALERT} \quad (11)$$

where w is the sliding window size.

Coordination Defenses I

Byzantine-Tolerant Consensus

Theorem (Byzantine Agreement Requirement)

For n agents with at most f compromised:

$$n \geq 3f + 1 \tag{12}$$

Definition (Cognitive Byzantine Agreement)

$$\mathcal{B}_{\text{consensus}}(\phi) = \begin{cases} 1 & \text{if } |\{i : \mathcal{B}_i(\phi) > \tau\}| > \frac{2n}{3} \\ 0 & \text{if } |\{i : \mathcal{B}_i(\phi) < 1 - \tau\}| > \frac{2n}{3} \\ \perp & \text{otherwise} \end{cases} \tag{13}$$

Coordination Defenses II

Quorum Verification

Definition (Quorum Requirement)

Critical actions require multi-agent approval:

$$\text{Permit}(\text{action}) \iff |\{a_i : \text{approve}_i(\text{action})\}| \geq q \quad (14)$$

where $q = \lceil \frac{n+f+1}{2} \rceil$.

Spotcheck Pattern

Spotcheck Protocol:

1. Assign task T to agent A
2. With probability p_{check} : assign same task to verifier V
3. Compare results R_A, R_V
4. If divergent: escalate to human
5. Track accuracy per agent for reputation

Defense Composition I

Defense Composition II

Composition Algebra

Definition (Defense Composition)

Defenses compose in series ($\circ$) or parallel ($\parallel$):

Series Composition (both must pass):

$$\mathcal{D}_1 \circ \mathcal{D}_2 : \text{ACCEPT} \iff \mathcal{D}_1(m) = \text{ACCEPT} \wedge \mathcal{D}_2(m) = \text{ACCEPT} \quad (15)$$

Parallel Composition (any can detect):

$$\mathcal{D}_1 \parallel \mathcal{D}_2 : \text{DETECT} \iff \mathcal{D}_1(m) = \text{DETECT} \vee \mathcal{D}_2(m) = \text{DETECT} \quad (16)$$

Theorem (Series Detection Rate)

For series composition:

$$P_{\text{detect}}(\mathcal{D}_1 \circ \mathcal{D}_2) = P_{\text{detect}}(\mathcal{D}_1) + (1 - P_{\text{detect}}(\mathcal{D}_1)) \cdot P_{\text{detect}}(\mathcal{D}_2) \quad (17)$$

Proof.

Cost-Benefit Analysis I

Definition (Defense Cost)

Total cost of defense deployment:

$$C_{\text{total}}(\mathcal{D}) = C_{\text{compute}} + C_{\text{latency}} + C_{\text{fp}} + C_{\text{maint}} \quad (23)$$

Table 7: Cost model components.

Component	Formula	Unit
Compute	$\sum_d c_d \cdot f_d$	CPU-hours/day
Latency	$\sum_d L_d \cdot r_{\text{msg}}$	User-seconds/day
False Positive	$\text{FPR} \cdot r_{\text{msg}} \cdot c_{\text{review}}$	Analyst-hours/day
Maintenance	$ \mathcal{D} \cdot c_{\text{maint}}$	Eng-hours/month

Definition (Defense Benefit)

Expected loss prevented:

$$B_{\text{total}}(\mathcal{D}) = P_{\text{attack}} \cdot P_{\text{detect}}(\mathcal{D}) \cdot L_{\text{prevented}} \quad (24)$$

Cost-Benefit Analysis II

Table 8: Cost-benefit analysis by defense mechanism.

Defense	Compute	Latency	FP	Cost	Benefit	ROI
Firewall	10^3	10ms	Medium	High		4.2x
Sandbox	10^2	5ms	Low	Medium		3.1x
Tripwires	10^1	1ms	Low	Medium		5.8x
Drift Detection	10^4	20ms	High	High		2.3x
Invariant Check	10^2	5ms	Low	High		4.7x
Byzantine	10^5	100ms	Medium	Very High		1.8x
Spotcheck	10^4	Variable	Low	Medium		2.9x

Cost-Benefit Analysis III

Optimal Defense Portfolio

Definition (Portfolio Optimization)

$$\max_{\mathcal{D} \subseteq \mathcal{D}_{\text{all}}} B_{\text{total}}(\mathcal{D}) - C_{\text{total}}(\mathcal{D}) \quad (25)$$

subject to: $C_{\text{compute}}(\mathcal{D}) \leq B_{\text{compute}}$, $\max_d L_d \leq L_{\text{max}}$,
 $\text{FPR}(\mathcal{D}) \leq \epsilon_{\text{fp}}$.

Table 9: Deployment recommendations by risk profile.

Risk Profile	Recommended Stack	Cost	Detection
Low (internal)	Firewall + Tripwires	Low	88%
Medium (business)	+ Sandbox + Invariants	Medium	94%
High (financial)	+ Drift + Spotcheck	High	97%
Critical (infra)	Full + Byzantine	Very High	99.5%

Defense Mechanism Detection Overlap

Cognitive
Firewall

Belief
Sandbox

Formal Defense Composition Guarantees I

This section provides rigorous formal guarantees for the five canonical CIF defenses and their composition algebra. These results extend the composition theorems from Section~?? with complete proofs and explicit security bounds.

Formal Defense Composition Guarantees II

Canonical Defense 1: Cognitive Firewall — Formal Specification

The Cognitive Firewall

$\mathcal{F} : \mathcal{M} \rightarrow \{\text{ACCEPT}, \text{QUARANTINE}, \text{REJECT}\}$ is fully specified by three properties:

Theorem (Firewall Completeness)

The cognitive firewall classifies every message into exactly one of three outcome classes:

$$\forall m \in \mathcal{M} : |\{\mathcal{F}(m)\}| = 1 \wedge \mathcal{F}(m) \in \{\text{ACCEPT}, \text{QUARANTINE}, \text{REJECT}\} \quad (26)$$

Theorem (Firewall False Positive Monotonicity)

Increasing the rejection threshold τ_1 decreases false positive rate and decreases true positive rate monotonically:

$$\tau'_1 > \tau_1 \Rightarrow FPR(\tau'_1) \leq FPR(\tau_1) \wedge TPR(\tau'_1) \leq TPR(\tau_1) \quad (27)$$